

Introdução à Segurança

CST em Análise e Desenvolvimento de Sistemas

Prof. Emerson Ribeiro de Mello

mello@ifsc.edu.br

Licenciamento



Slides licenciados sob [Creative Commons "Atribuição 4.0 Internacional"](https://creativecommons.org/licenses/by/4.0/)

Sumário

- 1 Vulnerabilidade, ameaça e ataque
- 2 Propriedades básicas de segurança
- 3 Classificação de ataques

Segurança computacional, cibersegurança ou segurança cibernética

Consiste em proteger sistemas de computadores, redes de computadores e dados contra ataques, danos ou acessos não autorizados de forma a garantir a confidencialidade, integridade e disponibilidade dos sistemas e dados

- Como evitar que uma pessoa, com acesso físico ao telefone, possa fazer ligações?



Fonte: Google Images

- Como evitar que uma pessoa, com acesso físico ao telefone, possa fazer ligações?
- **Resposta:** Adicione um cadeado ao telefone!



Fonte: Google Images

- Como evitar que uma pessoa, com acesso físico ao telefone, possa fazer ligações?
- **Resposta:** Adicione um cadeado ao telefone!
- Resolveu o problema ou apenas limitou o acesso de pessoas com menos habilidades?



Fonte: Google Images

Qual das duas fechaduras é menos suscetível de ser aberta por uma pessoa não autorizada?



Fonte: Google Images



Fonte: Google Images

Qual das duas fechaduras é menos suscetível de ser aberta por uma pessoa não autorizada?

- É possível ser aberta por pessoas com habilidade, ferramentas, tempo e acesso físico ao local



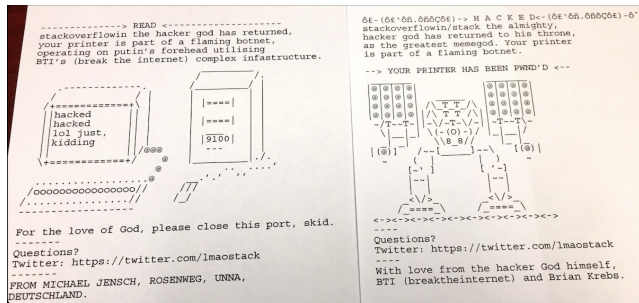
Fonte: Google Images



Fonte: Google Images

- É possível ser aberta por pessoas com habilidade, ferramentas, tempo e NÃO precisa ter acesso físico ao local

Alguns casos relacionados à cibersegurança



Fonte: <https://twitter.com/StephSanchezPhD/status/828670493377040385>

- 2017 um hacker invadiu 160 mil impressoras conectadas à Internet e fez com que elas imprimissem arte ASCII e um aviso para fecharem as portas¹

¹ https://www.theregister.com/2017/02/06/hacker_160000_printers/

Alguns casos relacionados à cibersegurança

- Em 2015 pesquisadores mostraram que era possível hackear um carro Jeep Cherokee e controlar remotamente o sistema de freios, motor e outros sistemas
- Carros antigos sem conexão à Internet não são vulneráveis a esse tipo de ataque, porém atualmente a maioria dos carros novos possuem conexão à Internet



Fonte: <https://www.wired.com/2015/07/hackers-remotely-kill-jEEP-highway>

Nexx Smart Wi-Fi Garage Door

<https://www.cisa.gov/news-events/ics-advisories/icsa-23-094-01>

- Todos dispositivos compartilham a mesma credencial de acesso aos servidores MQTT da Nexx
- Dados pessoais do cliente, ID do dispositivo e comandos para abrir ou fechar o portão são enviados sem qualquer criptografia
- 04/jan/2023 – pesquisador entrou em contato com a empresa²
- Mais de 4 meses sem resposta



²<https://medium.com/@samsabetan/the-uninvited-guest-idors-garage-doors-and-stolen-secrets-e4b49e02dad6>

Qualidade de *software* e segurança

- Já usou algum *software* que travou ou que apresentou um comportamento errôneo?
 - Aprendemos a compensar esses problemas. Por exemplo, salvando o trabalho frequentemente
- **Softwares estão repletos de *bugs***, sendo alguns deles inerentes à complexidade do *software*, relacionados a dependências externas (bibliotecas) e à falta de qualidade

Qualidade de *software* e segurança

- Já usou algum *software* que travou ou que apresentou um comportamento errôneo?
 - Aprendemos a compensar esses problemas. Por exemplo, salvando o trabalho frequentemente
- **Softwares estão repletos de *bugs***, sendo alguns deles inerentes à complexidade do *software*, relacionados a dependências externas (bibliotecas) e à falta de qualidade

A maioria dos softwares é desenvolvida sem a preocupação com a segurança e a qualidade do *software* é frequentemente sacrificada em detrimento do prazo de entrega

Qualidade de *software* e segurança

- **Qualidade de *software*** é a conformidade com os requisitos funcionais e de desempenho, padrões de desenvolvimento e características implícitas que são esperadas de todo *software* desenvolvido profissionalmente
- **Segurança de *software*** é a conformidade com os requisitos de segurança de todo *software* desenvolvido profissionalmente

Segurança é sempre uma troca (Schneier, 2020)

- Segurança vs funcionalidades
- Segurança vs conveniência (usabilidade)
- Segurança vs desempenho
- Segurança vs custo

Internet das coisas (IoT) e implicações de segurança

- Assistentes de voz, termostatos, câmeras de segurança, lâmpadas, geladeiras, máquinas de lavar roupa, ar condicionado, brinquedos, etc.
- Economia de mercado fará com que a maioria dos dispositivos eletrônicos tenham conexão à Internet
- E se houver uma vulnerabilidade de segurança em um desses dispositivos? Como seria possível corrigir? E se o fabricante não mais existir?



Fonte: <https://www.samsung.com/br/>

Internet das coisas (IoT) e implicações de segurança

"Qualquer coisa conectada à Internet pode ser hackeada; Tudo está sendo conectado à Internet; Portanto, tudo está tornando-se vulnerável, Rod Beckstrom (Schneier, 2020)"

Vulnerabilidade, ameaça e ataque

Vulnerabilidade

Vulnerabilidade

Fraqueza do sistema que pode ser em termos de procedimentos, configuração ou implementação e que pode ser explorada por um atacante para violar a segurança do sistema

- Existem em *software* e *hardware*
- Podem ser descobertas facilmente ou demorar anos para serem descobertas
- Podem ser corrigidas facilmente ou ser impossíveis de corrigir

Vulnerabilidade de dia zero

Zero-day vulnerability

- Vulnerabilidade que ainda não é conhecida pelo fabricante do *software* ou *hardware* ou que ainda não foi corrigida por esse
 - São as mais críticas e perigosas, pois os usuários não têm como se proteger
 - São descobertas por pesquisadores de segurança, *hackers* ou agências de inteligência
 - São vendidas e podem ser usadas em ataques direcionados
- **Google Project Zero**³ é um time de pesquisadores de segurança que buscam por vulnerabilidades de dia zero em *hardwares* e *softwares* dos quais usuários do mundo todo dependem
 - Participaram da descoberta das vulnerabilidades Spectre e Meltdown

³<https://googleprojectzero.blogspot.com>

Exemplo de vulnerabilidade em *hardware*

Spectre (CVE-2017-5753, CVE-2017-5715) e Meltdown (CVE-2017-5754)^{4,5}

- Falha de projeto de processadores da Intel x86 produzidos depois de 1995, mas alguns processadores AMD e ARM também são afetados
 - Demoraram dez anos para serem descobertas (2017) e afeta a maioria dos dispositivos eletrônicos
- Permite que um processo malicioso leia a memória de outros processos
 - Não explora qualquer vulnerabilidade de *software*
- Correções contra o Meltdown foram lançadas para Linux, Windows e macOS, mas impactam no desempenho (até 30%)
- Correções para o Spectre são mais difíceis de serem aplicadas e podem não ser eficazes

⁴<https://meltdownattack.com>

⁵<https://www.youtube.com/watch?v=RbHbFkh6eeE>

Exemplo de vulnerabilidade em *software*

Apache Log4J (CVE-2021-44228) – Log4Shell – <https://www.ibm.com/think/topics/log4j>

- Log4J é uma biblioteca de *logging* muito popular em aplicações Java

Data	Evento
24/11/2021	Vulnerabilidade de dia zero que permite a execução remota de código arbitrário
09/12/2021	Prova de conceito para explorar a vulnerabilidade
10/12/2021	1º patch, mas introduziu outra vulnerabilidade
14/12/2021	2º patch, mas introduziu outra vulnerabilidade
–	3º patch, mas introduziu outra vulnerabilidade
–	4º patch sanou as vulnerabilidades conhecidas

Tempo entre descoberta e correção de vulnerabilidade

- O ataque WannaCry (2017) explorou uma vulnerabilidade já corrigida pela Microsoft, mas muitos sistemas não foram atualizados a tempo
- Administradores podem atrasar atualizações por medo de causar problemas
 - Em julho de 2024, uma atualização do CrowdStrike⁶ deixou sistemas Windows inoperantes
- Usuários muitas vezes não aplicam correções por falta de conhecimento ou atenção

⁶https://en.wikipedia.org/wiki/2024_CrowdStrike_incident

Descoberta de vulnerabilidades I

Como saber se o seu *software* está seguro?

Você confiaria cegamente no seu código?

Vulnerabilidades podem estar escondidas em qualquer parte do sistema, esperando para serem exploradas

- Existem diversas técnicas para descobrir falhas:
 - **Fuzzing:** Testes automáticos que enviam dados inesperados para o sistema
 - **Análise estática:** Examina o código sem executá-lo, buscando padrões inseguros
 - **Análise dinâmica:** Observa o comportamento do sistema em tempo real

Descoberta de vulnerabilidades II

Como saber se o seu *software* está seguro?

- Ferramentas automáticas podem ser suas aliadas:
 - **GitHub Dependabot**, **Snyk**, **mend.io**, **SonarQube**, entre outras
 - Elas ajudam a identificar e corrigir vulnerabilidades antes que se tornem problemas reais

Dica

Grandes empresas e projetos de código aberto usam essas técnicas e ferramentas diariamente para proteger milhões de usuários

Programa de recompensa por vulnerabilidades

Bug bounty

- **Bug bounty** é um programa de recompensa para pesquisadores que descubrem e relatam vulnerabilidades
 - <https://security.apple.com/bounty/>
 - <https://pt-br.facebook.com/whitehat/>
 - <https://www.google.com/about/appsecurity/reward-program/>
 - <https://www.microsoft.com/en-us/msrc/bounty>

Programa de recompensa por vulnerabilidades

Exemplo de recompensas do Bug bounty da Apple – 2024

Network attack without user interaction	Zero-click radio to kernel with physical proximity	\$5,000 – \$500,000
	Zero-click unauthorized access to sensitive data	\$5,000 – \$500,000
	Zero-click kernel code execution with persistence and kernel PAC bypass	\$100,000 – \$1,000,000

Fonte: <https://security.apple.com/bounty/categories/>

Catálogo de vulnerabilidades

*Common Vulnerabilities and Exposures (CVE)*⁹

- Sistema internacional para identificar, definir e catalogar vulnerabilidades de cibersegurança conhecidas publicamente
- Cada vulnerabilidade recebe um identificador único, por exemplo: CVE-2023-12345
- CVE não fornece detalhes técnicos ou correções, mas serve como referência para fabricantes, pesquisadores e ferramentas de segurança
- Bancos de dados como NVD⁷ e Exploit-DB⁸ usam CVE como base para informações detalhadas e exploits

⁷<https://nvd.nist.gov>

⁸<https://www.exploit-db.com>

⁹<https://www.cve.org>

Catálogo de fraquezas

*Common Weakness Enumeration (CWE)*¹¹

- Catálogo padronizado de fraquezas de software e hardware que podem se tornar vulnerabilidades
- Ajuda desenvolvedores, analistas e ferramentas a identificar, classificar e mitigar fraquezas desde o início do ciclo de desenvolvimento
- Exemplos:
 - Escrita fora dos limites de um *buffer* (CWE-787)
 - Validação insuficiente de entrada em páginas web (CWE-20)
 - Injeção de comandos SQL (CWE-89)
- Em 2023, as principais fraquezas ainda estão relacionadas ao uso inseguro de memória em linguagens como C e C++¹⁰

¹⁰ <https://www.memorysafety.org/docs/memory-safety>

¹¹ <https://cwe.mitre.org/about/>

Exemplo de fraqueza

Validação insuficiente de entrada

```
// Exemplo de código que não valida corretamente a entrada do usuário
public void buscarUsuario(String id) throws SQLException {
    String query = "SELECT * FROM usuarios WHERE id = " + id;
    Statement stmt = conn.createStatement();
    ResultSet rs = stmt.executeQuery(query);
}
```

- O código acima permite que o usuário insira qualquer valor em `id`, inclusive comandos maliciosos
- Pode ser explorado por um atacante para executar *SQL Injection*

Exemplo de fraqueza

Validação insuficiente de entrada

```
// Exemplo de código que valida corretamente a entrada do usuário
public void buscarUsuario(String id) throws SQLException {
    String query = "SELECT * FROM usuarios WHERE id = ?";
    PreparedStatement pstmt = conn.prepareStatement(query);
    pstmt.setString(1, id);
    ResultSet rs = pstmt.executeQuery();
}
```

- O código acima utiliza parâmetros na consulta, evitando a exploração por *SQL Injection*

Segurança desde a concepção I

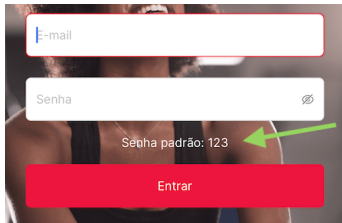
Security by Design

- **Security by Design** é um princípio^{12,13} que prioriza a segurança desde o início do ciclo de vida do *software*, considerando ameaças, requisitos e controles já na fase de projeto
- Sistemas desenvolvidos com essa abordagem são seguros por padrão, ou seja, já vêm configurados para minimizar riscos sem exigir ações adicionais de usuários ou administradores
- O objetivo é evitar vulnerabilidades estruturais, reduzir a superfície de ataque e facilitar a manutenção da segurança ao longo do tempo

Segurança desde a concepção II

Security by Design

Insecure design



Março de 2024. Fonte: omitida

- Todos usuários novos são criados com a mesma senha 123
- Para ter certeza que o usuário conseguirá fazer login, a senha é apresentada na página de *login*

¹² <https://www.cisa.gov/resources-tools/resources/secure-by-design>

¹³ <https://research.google/pubs/secure-by-design-at-google/>

Ameaça

Qualquer evento, ação, pessoa ou entidade que tem o potencial de causar danos a um sistema ou organização

- **Ameaças físicas**, como roubo, vandalismo, desastres naturais
- **Ameaças lógicas**, como *malware*, engenharia social
- **Ameaças internas**, como funcionários desonestos
- **Ameaças acidentais**, como erros de configuração, falhas de hardware, desastres naturais

A ameaça é o ponto de partida para a segurança, pois é necessário entender o que pode acontecer para poder se proteger

Ataque

Concretização de uma ameaça, explorando uma vulnerabilidade para causar danos a um sistema ou organização

- Ataques podem ser direcionados ou indiscriminados
- Ataques podem ser de curto ou longo prazo

Ataques estão ficando mais fáceis, baratos e eficazes

Padrão de criptografia DES

- 1975 – DES (*Data Encryption Standard*) é proposto
- 1976 – Especialistas estimaram que seria necessário US\$ 20 milhões para quebrá-lo
- 1997 – DES foi quebrado por menos de US\$ 250 mil
- 2012 – Pesquisadores quebraram o DES em 2 dias usando uma máquina de US\$ 10 mil
- Hoje – É possível quebrar o DES em minutos usando um computador pessoal

Ataques estão ficando mais fáceis, baratos e eficazes

Telefonia celular

- 1990 – Telefones celulares foram projetados para confiar em qualquer torre de celular
 - Era complexo para o telefone verificar se a torre era legítima
 - Era caro implantar torres falsas
- 1995 – FBI e CIA dispunham de torres falsas em seus carros¹⁴
- 2000 – Implantar torres falsas era tão fácil e barato que isso era demonstrado em conferências de segurança

¹⁴2024 – Tem carro com ERB falsa rodando por SP – <https://g1.globo.com/sp/sao-paulo/noticia/2024/07/25/carro-do-golpe-policia-investiga-quadrilha-que-usa-veiculo-com-antena-e-computador-para-rastrear-celulares-e-aplicar-golpes-em-sp.ghtml>

Ataques estão ficando mais fáceis, baratos e eficazes

Senhas de computador

- A velocidade dos computadores está aumentando de maneira exponencial, tornando-os mais rápidos para quebrar senhas e criptografias por **força bruta**
 - Método de ataque que tenta todas as combinações possíveis de uma senha
- A nossa capacidade em memorizar senhas longas e complexas não está aumentando na mesma velocidade
 - Senhas longas e complexas são difíceis de serem lembradas
 - Senhas curtas e simples são fáceis de serem quebradas (data de nascimento, nome do cachorro, placa do carro, etc)
- Senhas que poderiam ser seguras dez anos atrás, hoje não são mais
 - 5Wij247C, Mu1t0D1f1c1l, f0nt3H4ck3r, P@ssw0rd!

Cibersegurança

Envolve **pessoas, processos e tecnologia** para **proteger** a informação de **ameaças** e **garantir a continuidade** do negócio

"Segurança é um processo contínuo e não um produto"
Bruce Schneier

Não importa o quão robusto seja um controle técnico de segurança, se critérios não técnicos afetarem sua implementação ou uso, então a segurança pode ficar fragilizada



- Repetição de padrões nas mensagens transmitidas pela Enigma
- <http://www.imdb.com/title/tt2084970>

- Kevin Mitnick, um dos hackers mais famosos, disse que a engenharia social é a forma mais eficaz de invasão
- <http://www.imdb.com/title/tt0159784>



Pessoas internas transpondo mecanismos de segurança

Roubo de R\$ 541 mi da C&M Software¹⁵

- Em março/2025, assediaram um analista de backend da empresa para obter credenciais de acesso
 - Recebeu R\$ 15 mil para fornecer acesso ao sistema
- Em junho/2025, um grupo de criminosos conseguiu desviar R\$ 541 milhões da C&M software
 - Teve início às 4:00 e encerrou às 7:00

Elo mais fraco

As pessoas são o elo mais fraco da cadeia de segurança, e os atacantes sabem disso. Eles exploram a confiança, a curiosidade e a falta de conhecimento para obter acesso a sistemas críticos

¹⁵<https://www.cnnbrasil.com.br/nacional/brasil/ataque-hacker-o-que-sabemos-sobre-golpe-que-desviou-r-541-milhoes/>

Propriedades básicas de segurança

Propriedades básicas de segurança

Confidentiality, Integrity, Availability (CIA triad)



Fonte: Operational Technology

Cybersecurity for Energy Systems

■ Confidencialidade

- A informação só deve ser revelada para usuários autorizados

■ Integridade

- A informação não deve ser alterada, destruída ou perdida, de maneira não autorizada ou acidental

■ Disponibilidade

- A informação deve estar disponível quando necessário

É necessário garantir as três propriedades para que a informação seja considerada segura

Confidencialidade

- Confidencialidade deve ser garantida durante a transmissão, processamento e armazenamento da informação
- A confidencialidade pode ser garantida por meio de mecanismos como criptografia e controle de acesso
- **Se a confidencialidade não for garantida**, então tem-se uma revelação não autorizada de informação

Confidencialidade

- Confidencialidade deve ser garantida durante a transmissão, processamento e armazenamento da informação
- A confidencialidade pode ser garantida por meio de mecanismos como criptografia e controle de acesso
- **Se a confidencialidade não for garantida**, então tem-se uma revelação não autorizada de informação

Nota

Privacidade é um aspecto da confidencialidade, mas não é a mesma coisa. Privacidade é a capacidade de controlar a informação sobre si mesmo. A confidencialidade é a capacidade de controlar a informação de forma geral

Integridade

- Somente partes autorizadas podem alterar a informação
 - Também garante o não repúdio e a autenticidade da informação
- A integridade pode ser verificada por meio de mecanismos como *checksum* e assinaturas digitais
 - Tais mecanismos não impedem a alteração, mas permitem detectá-la
- **Se a integridade não for garantida**, então tem-se uma alteração não autorizada ou destruição da informação

Disponibilidade

- A informação deve estar disponível quando necessário
- Pode-se garantir a disponibilidade por meio de redundância, backups, sistemas de energia ininterrupta, etc
- **Se a disponibilidade não for garantida**, então tem-se uma disrupção no acesso ou no uso da informação

Outras propriedades de segurança

Além da *CIA triad*

■ Autenticidade (*Authenticity*)

- Autenticidade de uma informação consiste em garantir que é proveniente de quem diz ser, ou seja, garantir a autoria da informação
- Também garante a autenticidade de uma entidade, garantindo que ela é quem diz ser

■ Responsabilidade (*Accountability*)

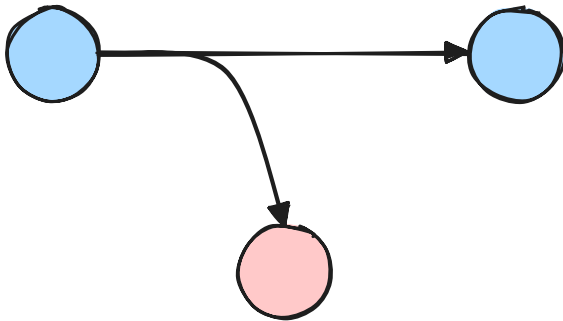
- Capacidade de rastrear ações até um indivíduo ou processo
- Em conjunto com a integridade e autenticidade, dá suporte ao **não repúdio**

Classificação de ataques

Classificação de ataques

Interceptação

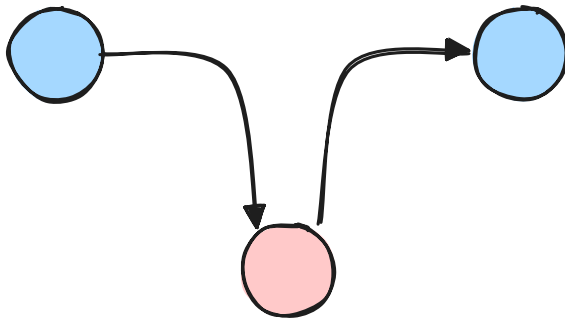
Parte não autorizada obtém acesso a uma informação



Classificação de ataques

Modificação

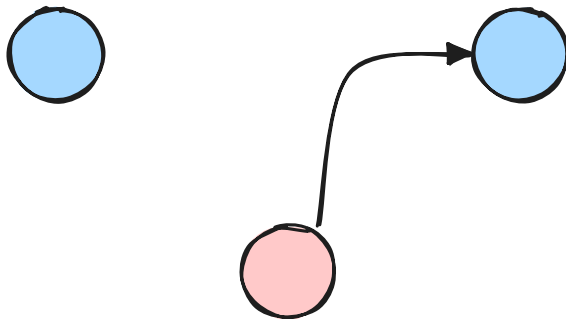
Parte não autorizada altera uma informação e a envia para o destinatário



Classificação de ataques

Personificação

Parte não autorizada envia uma informação como se fosse uma parte legítima



Classificação de ataques

Interrupção

Parte não autorizada interrompe a comunicação entre duas partes legítimas



Incidentes de segurança

Evento que compromete a confidencialidade, integridade ou disponibilidade de um sistema ou organização

- **Vazamento de dados** é um incidente de segurança que compromete a confidencialidade
- **Perda de dados** é um incidente de segurança que compromete a integridade
- **Indisponibilidade** é um incidente de segurança que compromete a disponibilidade

Incidentes de segurança

Exemplos

- 1 As notas de um estudante são alteradas no sistema acadêmico por uma pessoa não autorizada (ex. um aluno, um professor ou um técnico)
 - Como garantir a integridade das notas?

Incidentes de segurança

Exemplos

- 1 As notas de um estudante são alteradas no sistema acadêmico por uma pessoa não autorizada (ex. um aluno, um professor ou um técnico)
 - Como garantir a integridade das notas?
- 2 Em um hospital, um ataque de *ransomware* criptografa os prontuários dos pacientes
 - Como garantir a disponibilidade dos prontuários?

Incidentes de segurança

Exemplos

- 1 As notas de um estudante são alteradas no sistema acadêmico por uma pessoa não autorizada (ex. um aluno, um professor ou um técnico)
 - Como garantir a integridade das notas?
- 2 Em um hospital, um ataque de *ransomware* criptografa os prontuários dos pacientes
 - Como garantir a disponibilidade dos prontuários?
- 3 Um *hacker* obtém acesso a um banco de dados de uma empresa e rouba informações de cartões de crédito
 - Como garantir a confidencialidade das informações?

Incidentes de segurança

Exemplos

- 1 As notas de um estudante são alteradas no sistema acadêmico por uma pessoa não autorizada (ex. um aluno, um professor ou um técnico)
 - Como garantir a integridade das notas?
- 2 Em um hospital, um ataque de *ransomware* criptografa os prontuários dos pacientes
 - Como garantir a disponibilidade dos prontuários?
- 3 Um *hacker* obtém acesso a um banco de dados de uma empresa e rouba informações de cartões de crédito
 - Como garantir a confidencialidade das informações?
- 4 Os votos de uma eleição são alterados por um ataque cibernético
 - Como garantir a integridade dos votos ao mesmo tempo que se garante o sigilo do voto?

Resumo

- **Vulnerabilidade** é uma fraqueza do sistema que pode ser explorada por um atacante para violar a segurança do sistema
- **Ameaça** é qualquer evento, ação, pessoa ou entidade que tem o potencial de causar danos a um sistema
- **Ataque** é a concretização de uma ameaça, explorando uma vulnerabilidade para causar danos a um sistema ou organização
- **Propriedades básicas de segurança** são confidencialidade, integridade e disponibilidade
- **Cibersegurança** envolve pessoas, processos e tecnologia para proteger a informação de ameaças e garantir a continuidade do negócio

Aula baseada em



SCHNEIER, Bruce. **Clique aqui para matar todo mundo**. 2020. Disponível em:
<https://app.minhabiblioteca.com.br/reader/books/9788550808871>.



STALLINGS, William. **Criptografia e Segurança de Redes: Princípios e Práticas**. 4. ed. São Paulo: Pearson Prentice Hall, 2007. Tradução da 4ª edição norte-americana. ISBN 9788576050673.